VARENDRA UNIVERSITY

বরেন্দ্র বিশ্ববিদ্যালয়

VARENDRA UNIVERSITY

Dept. of CSE

Assignment

Course Code: CSE - 431

Course Title: Cryptography and network security

Submitted By	Submitted To
ID: 221311026 **Name:** Md. Balayet Hossain Shadhin **Sec:** A **29th Batch 9th Sem.** B.Sc. in Computer Science and Engineering at **Varendra University**	Sushmit Jahan Rose Lecturer **Dept. of CSE, Varendra University**

Q 1:

Consider an organization where all traffic between Branch A (192.168.10.0/24) and Head quarters (10.0.0.0/24) must be protected at the network layer, only HTTPS (TCP 443) and SSH (TCP 22) traffic from Branch A to HQ should be allowed and encrypted while all other traffic is blocked, and communication between two specific servers (192.168.10.10 at Branch A and 10.0.0.5 at HQ) must additionally be strongly authenticated and protected against replay attacks; explain in detail how IPSec can be used to meet these requirements by describing the roles of SPD and SAD, proposing appropriate SPD rules, describing the necessary security as sociations for at least one concrete flow, and narrating how a single packet from 192.168.10.10 to 10.0.0.5 is processed by IPSec on its outbound and inbound paths

ANS:

IPSec Use Between Branch A and HQ
1. Traffic Control Using IPSec Databases

- Policy List (SPD): Tells the system which packets must be protected, allowed, or dropped.
- Security Records (SAD): Holds the keys, SPIs, and settings needed to secure packets.

2. Rules Needed for This Network

- Allow and protect HTTPS (443) and SSH (22) from Branch A to HQ using ESP encryption + integrity.
- The server pair 192.168.10.10 → 10.0.0.5 must use extra-strong ESP, with strict authentication and replay protection.
- Any other traffic going from Branch to HQ must be blocked.

3. One Flow Example (10.10 → 0.5)

Outgoing:

- Packet matches SPD rule.
- IPSec pulls keys from SAD.
- Packet is wrapped in ESP, encrypted, authenticated, and sent.

Incoming:

- HQ checks the packet's SPI against SAD.
- Integrity + replay checks happen.
- ESP is removed and the real packet is delivered to the server.

Q 2:

A multinational company deploys IPSec over the public internet where several branch offices sit behind NAT devices and the network uses stateful firewalls that only allow specific ports; the company requires data origin authentication, integrity, confidentiality, and replay protection for inter-branch communication. Explain, in one coherent discussion, how Authen tication Header (AH) and Encapsulating Security Payload (ESP) differ in terms of what they protect in the IP packet, how they interact with NAT and firewalls, and what overhead and per formance implications they bring, then argue why AH commonly fails in NATed environments, and finally propose a realistic IPSec deployment (choice of AH/ESP, transport or tunnel mode, endpoint placement) that can operate correctly in this NAT and firewall-constrained scenario.

ANS:

IPSec Over Internet With NAT & Firewalls

1. What AH and ESP Protect

- AH: Protects the whole IP packet (including header) but does not encrypt the data.
- ESP: Encrypts the data and protects integrity but not the outer IP header.

2. NAT & Firewall Behavior

- AH breaks with NAT because NAT changes IP addresses, and AH checks the header—so the packet no longer matches.
- ESP works with NAT using NAT-Traversal (UDP encapsulation), which firewalls can allow.

3. Overhead Differences

- AH: Extra bits for authentication only (lighter).
- ESP: Adds encryption + authentication overhead (heavier but secure).

4. Why AH Fails in Real Deployments

- NAT rewrites IPs → AH thinks the packet was tampered → packet dropped.

5. Best Practical Setup

- Use ESP with encryption + integrity, tunnel mode, NAT-Traversal enabled.
- Run IPSec on branch gateways, so all branch traffic is protected before crossing the internet.

Q 3:

Two IPSec gateways are configured to use IKEv2 to establish ESP tunnel mode protec tion between networks 172.16.0.0/16 and 192.168.0.0/16; describe, in a detailed narrative, the complete IKEv2 process starting from the initial contact until the ESP Child SA is established, clearly naming the main message phases, explaining what cryptographic material (keys, algo rithms, nonces, Diffie–Hellman values) is negotiated or derived at each stage, then propose a concrete and realistic cryptographic suite (including DH group, encryption algorithm, integrity algorithm, and PRF) suitable for a secure yet efficient enterprise deployment, and finally analyze how Perfect Forward Secrecy (PFS) and the IKEv2 cookie mechanism contribute to long-term security and DoS in this setup.

ANS:

1. Initial Key Exchange (IKE_SA_INIT)

- Both gateways trade DH values and nonces.
- They select the encryption, integrity, and PRF algorithms.
- A shared secret is formed for protecting the next messages.

2. Authentication Stage (IKE_AUTH)

- Gateways prove identity using certificates or PSK.
- A Child SA for ESP is created with fresh keys for data traffic.
- All keys come from the DH shared value and nonces.

3. Strong Crypto Choices (Realistic Set)

- DH Group: 14 or 19
- Encryption: AES-256-GCM
- Integrity: SHA-256
- PRF: HMAC-SHA-256

4. Extra Security Features

- PFS: Ensures each new Child SA has a fresh DH exchange so old traffic stays protected.
- Cookies in IKEv2: Prevents DoS by making the initiator respond before the gateway commits resources.